

REV	DATA	MOTIVO	ITENS MODIFICADOS
0	17/02/2020	Emissão inicial	Nenhum
1	28/09/2020	Ajustes e melhorias identificadas para o procedimento.	Item 4 (eliminado parágrafo que abordava estilo de redação e perigos). Item 7 (melhorado esclarecimento sobre avaliação de controles existentes). Item 10 (alterada terminologia de “outros riscos “para “riscos gerais”). Acrescentado sumário.
2	15/10/2021	Adequação à versão 2020 da ISO/IEC 20000-1	Documento inteiro
3	31/07/2023	Adequação à ISO/IEC 27001:2022	Documento inteiro. Acrescentados: itens 3, 12 e Anexo 2. Eliminado anexo que apresentava as “interfaces da Gestão de risco com outros elementos do SGS”
4	02/02/2024	Atender recomendações da auditoria interna	Modificado item 4 e 5
5	17/03/2025	Reaprovação do documento	Nenhum
6	06/02/2025	Incremento do Controle A.5.02	Modificado o Item 3
7	09/02/2026	Revisão Anual	Item 3 atualizado

REV	DATA	APROVAÇÃO	
7	09/02/2026	Gerente de SOC	
		Gerente de suporte	

Este Documento e a informação nele contida são privativos das empresas Interjato Serviços de Telecomunicações Ltda e Interjato Telecom Ltda. A reprodução de quaisquer partes deste Documento está condicionada à autorização por parte das organizações.

SUMÁRIO

1. OBJETIVO	2
2. DEFINIÇÕES	2
3. CONTROLES ASSOCIADOS A ESTE PROCEDIMENTO	3
4. RESPONSABILIDADE E AUTORIDADE	3
5. IDENTIFICAÇÃO DE PERIGOS E AMEAÇAS	4
6. IDENTIFICAÇÃO DE RISCOS	5
7. CLASSIFICAÇÃO DE RISCOS	6
7.1 Avaliação das consequências	7
7.2 Avaliação da probabilidade	8
7.3 Determinação da significância do risco	9
8. AVALIAÇÃO DOS CONTROLES EXISTENTES	9
9. AVALIAÇÃO DA NECESSIDADE DE TOMADA DE AÇÃO ADICIONAL AOS CONTROLES EXISTENTES	11
10. PLANO DE AÇÃO	12
11. DOCUMENTAÇÃO	12
12. AVALIAÇÃO DA EFICÁCIA DO TRATAMENTO	13
13. ANEXOS	13
Anexo 01 – Modelo de Matriz de Risco para uso no SGS	14
Anexo 02 – Modelo de Matriz de Risco para uso no SGSI	15

1. OBJETIVO

Estabelecer os critérios e métodos para identificação, análise e avaliação dos riscos relacionados aos processos necessários para o Sistema de Gestão de Serviços (SGS), Sistema de Gestão de Segurança da Informação (SGSI) e aos ativos de informação, de forma a subsidiar a tomada de decisões e facilitar o alcance dos resultados pretendidos na gestão.

2. DEFINIÇÕES

- **Ativos de informação:** É o alvo direto ou indireto de um evento.
- **Evento:** Ocorrência ou mudança em um conjunto específico de circunstâncias
- **Confidencialidade:** Propriedade onde as informações são acessíveis apenas a entidades autorizadas;
- **Continuidade:** capacidade da organização de continuar a entrega de produtos ou serviços em um nível aceitável previamente definido após incidentes de interrupção;
- **Disponibilidade:** Situação na qual a informação pode ser obtida sempre que for necessário;
- **Ameaça:** Causa potencial de um incidente que pode resultar em danos a um sistema ou prejuízos a uma organização.
- **Vulnerabilidade:** Fraqueza de um ativo ou controle que pode ser explorada.

- **Incidente de segurança da informação** – Evento ou série de eventos indesejados ou inesperados de segurança da informação que possuem uma probabilidade significativa de comprometer as operações empresariais e ameaçar a segurança das informações.
- **Integridade:** Propriedade de dados que não foram alterados ou destruídos de maneira não autorizada e não detectada;
- **Proprietário do risco:** Pessoa ou entidade (Ex.: setor) com a responsabilidade e autoridade para gerenciar um risco.
- **Risco:** É o efeito da incerteza nos objetivos;
- **Risco Aceitável:** Risco que foi reduzido a um nível que pode ser tolerado pela organização levando em consideração suas obrigações legais e sua Política de Gestão;
- **Risco absoluto:** É o risco bruto, antes da implementação de qualquer estratégia de tratamento de risco;
- **Risco residual:** Risco remanescente após o tratamento do risco;
- **SLA:** Acordo do Nível de Serviços

3. CONTROLES ASSOCIADOS A ESTE PROCEDIMENTO¹

- A.5.02 – Papéis e Responsabilidades em Segurança da Informação
- A.5.06 – Contato com grupos de interesse especial
- A.5.07 – Inteligência de ameaças
- A.5.19 – Segurança da informação nas relações com fornecedores
- A.5.21 – Gestão da segurança da informação na cadeia de fornecimento de TIC
- A.5.23 – Segurança da informação para uso de serviços em nuvem
- A.8.08 – Gestão de vulnerabilidades técnicas

4. RESPONSABILIDADE E AUTORIDADE

Ação	Responsabilidade	Autoridade
Identificar os perigos e avaliar os riscos e medidas de controle existentes	Gestores das áreas envolvidas nos processos do SGS e com os ativos de informação	
Realizar o levantamento de vulnerabilidades técnicas	SOC	
Aprovar ações adicionais de controle, quando forem necessárias para tornar o risco aceitável	Gerente de NOC/SOC	
Analisar a eficácia das ações tomadas em relação aos riscos	Gerente de NOC/SOC	

Quadro 1 – Responsabilidades e autoridades

¹ Controles previstos no Anexo A da ISO/IEC 27001

5. IDENTIFICAÇÃO DE PERIGOS E AMEAÇAS

A identificação de perigos e ameaças deve ser realizada a partir:

- **Inventário de vulnerabilidades detectadas.** A base de conhecimento está na ferramenta de mesmo nome no grupo de trabalho do SOC no Bitrix, que é usada como subsídio de consulta para vulnerabilidades detectadas pela equipe de SOC que em suas atribuições de inteligência de ameaças, busca continuamente as vulnerabilidades técnicas.
- **Análise das etapas dos processos necessários para o Sistema de Gestão de Serviços**
- Para tanto, pode-se utilizar dados históricos e a experiência acumulada da empresa, discussões com os responsáveis pelos processos e outras fontes relevantes (ex.: literatura técnica, normas externas etc.).

Devem ser considerados, no mínimo, os perigos e ameaças relacionados a(ao):

- Uso dos produtos ou serviços dos fornecedores
- Incidentes de segurança da informação
- Possibilidades de interrupção/continuidade e a disponibilidade de serviço
- Ativos de informação², inclusive aqueles localizados fora das instalações da organização (Ex.: em trabalho remoto)
- Instalações, incluindo escritórios, salas e instalações
- Solicitações de mudanças
- Tratamento de não-conformidades
- Alteração em Itens de Configuração
- Serviços novos ou modificados
- Custos decorrentes de novos investimentos, novos serviços etc.

Para auxiliar esta etapa, é útil considerar as fontes de ameaças apresentadas no quadro 2³:

Fontes	Descrição
Adversárias • Concorrentes da organização • Concorrentes dos clientes da organização • Colaboradores insatisfeitos em atuação ou desligados	Indivíduos, grupos ou organizações que buscam explorar a dependência da organização em relação aos recursos de informação
Acidentais • Usuários • Usuários privilegiados/Administradores	Ações errôneas tomadas por indivíduos durante a realização de suas responsabilidades rotineiras
Estruturais • Hardware • Software • Sistemas internos ou remotos de suporte (energia, ar-condicionado etc.)	Falhas de equipamentos, controles ambientais ou software devido ao envelhecimento, esgotamento de recursos ou outras circunstâncias.

² O inventário de Ativos de informações é realizado conforme o PG-17 (Gestão de Ativos de Informação)

³ Adaptado de NIST Special Publication 800-30 Revision 1 (2012) Guide for Conducting Risk Assessments

Ambientais • Chuvas intensas • Incêndio • Falha no fornecimento de links de internet • Falha no fornecimento de energia	Catástrofes naturais e falhas de infraestruturas críticas em que a organização depende, mas que estão fora o controle da organização
---	--

Quadro 2 – Fontes de ameaças

6. IDENTIFICAÇÃO DE RISCOS

A identificação dos riscos refere-se às consequências indesejadas, decorrentes de um perigo ou ameaça, lembrando que pode haver combinações entre as fontes e os efeitos:

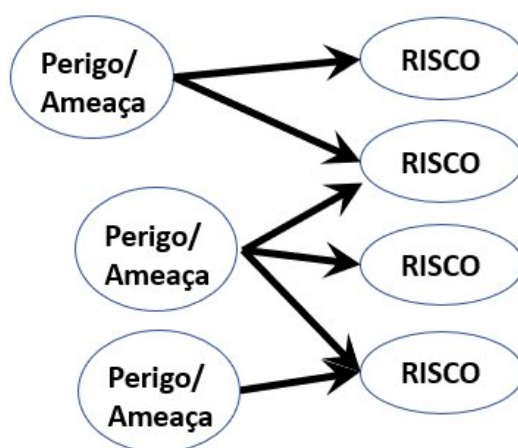


Figura 1 - Relação entre perigos e riscos em uma etapa de processo

Embora o risco seja composto pelo produto consequência x probabilidade, é a consequência que o descreve. Desta forma, os riscos devem ser descritos tendo em mente os efeitos que podem ser causados por um determinado perigo/ameaça. Exemplo: para o perigo: "*Descumprimento de procedimento*", pode-se ter como riscos associados:

- Retrabalho
- Descumprimento do SLA
- Custos adicionais
- Insatisfação de clientes
- Imagem negativa associada à empresa
- Perda de informações

7. CLASSIFICAÇÃO DE RISCOS

Os riscos são divididos em três faixas, conforme a aplicação dos critérios definidos neste procedimento:

- a) uma **faixa superior**, onde o nível de risco é considerado intolerável quaisquer que sejam os benefícios que possam trazer à atividade, e o tratamento de risco é essencial qualquer que seja o seu custo;
- b) uma **faixa intermediária** onde os custos e benefícios são levados em consideração, e oportunidades são comparadas com potenciais consequências⁴;
- c) uma **faixa inferior**, onde o nível de risco é considerado desprezível ou tão pequeno que nenhuma medida de tratamento de risco é necessária.

Para enquadramento nestas faixas, são adotados parâmetros para consequências e probabilidade. **Importante:** As avaliações descritas nos itens 7.1 e 7.2 referem-se aos riscos antes da aplicação de controles, ou seja, referem-se ao **risco absoluto**.

7.1 Avaliação das consequências

Para a avaliação das consequências, deve-se considerar a extensão do dano e/ou impacto negativo, caso o perigo se torne realidade, independentemente de sua probabilidade. Cada risco identificado deve ser avaliado quanto à suas consequências conforme a escala apresentada no quadro 1.

Para um determinado risco, os impactos podem ocorrer: a) em apenas uma área, por exemplo, para um risco de perda financeira, decorrente de um investimento inadequado, o efeito poderá ocorrer apenas nos negócios (coluna 3 do quadro 1) ou b) em mais de uma área, por exemplo para um incidente grave de segurança de informações que pode afetar as três áreas de análise.

Nota	Nível	Significado (impactos associados)		
		Negócio	Serviços	Segurança da Informação
5	Catastrófico	Perda financeira que não pode ser suportada pela organização, levando à necessidade de fechamento, recuperação judicial ou falência.	Interrupção total e por longo prazo da continuidade e a disponibilidade de serviço.	Perda significativa e permanente da confidencialidade, integridade ou disponibilidade (C/I/D) de ativos de informação importantes. Os titulares de DP podem encontrar consequências significativas, ou mesmo irreversíveis, que não podem superar.
4	Maior	Perda financeira significativa, mas que pode ser gerida pela organização. Significativos danos à imagem. Objetivos	Interrupção parcial (temporária ou não), mas relevante da continuidade e a disponibilidade de serviço.	Perda temporária, mas relevante da C/I/D ativos de informação importantes. Os titulares de DP podem encontrar consequências significativas, que podem ser capazes de superar, embora com

⁴ Nesta faixa, o conceito aplicável é procurar o nível de risco tão baixo quanto seja razoavelmente praticável (ALARP). Em outras palavras, é uma região onde se procura o melhor custo-benefício.

		organizacionais severamente prejudicados.		sérias dificuldades
3	Moderado	Perda financeira moderada. Os efeitos podem causar insatisfação e reclamações de clientes e podem impactar a imagem da organização. Objetivos organizacionais impactados.	Descumprimento de SLA previsto em acordos e contratos, podendo causar notificações e multas. A resolução exigirá ações internas e/ou externas.	Perda pontual da C/I/D de ativos de informação importantes. A resolução exigirá ações internas e/ou externas. Os titulares de DP podem encontrar inconvenientes significativos, que eles serão capazes de superar, apesar de algumas dificuldades
2	Menor	Pequenos custos envolvidos. Objetivos organizacionais pouco impactados.	Os efeitos podem causar pequeno atraso na entrega serviços, dentro da margem permitida por acordos e contratos, mas podem ser corrigidos dentro da organização sem causar insatisfação de clientes.	Perda pontual da C/I/D de ativos de informação não classificados como importantes, que afeta apenas o público interno. A resolução exigirá apenas ações internas. Os titulares de DP poderão encontrar alguns inconvenientes, os quais serão superados sem nenhum problema
1	Insignificante	Custos insignificantes Nenhum efeito mensurável nos objetivos organizacionais.	Efeitos que podem ser corrigidos dentro da organização, sem causar maiores prejuízos, não afetam os serviços e nem a satisfação de clientes.	Perda pontual da C/I/D de ativos de informação não classificados como importantes, que não afeta o público interno ou externo. Os titulares de DP não serão afetados

Quadro 3 - Avaliação de consequências

7.2 Avaliação da probabilidade

Nota	Descrição	Significado
5	Quase certo	Espera-se que ocorra na maioria das vezes. Por exemplo, todos os dias ou mais de uma vez por semana
4	Provável	Provavelmente ocorrerá na maioria das vezes. Por exemplo, uma vez por mês
3	Possível	Deverá ocorrer alguma vez. Por exemplo, uma vez por ano.
2	Improvável	Poderá ocorrer alguma vez. Por exemplo, uma vez a cada

		cinco anos
1	Raro	Poderá ocorrer somente em circunstâncias excepcionais. Por exemplo, uma vez a cada dez anos ou mais

Quadro 4 - Classificação de probabilidades

7.3 Determinação da significância do risco

Com base na avaliação de consequência e probabilidade, a avaliação da significância de cada risco identificado é dada pela matriz apresentada no quadro 3:

Probabilidade (P) Frequência	5	5	10	15	20	25
	4	4	8	12	16	20
	3	3	6	9	12	15
	2	2	4	6	8	10
	1	1	2	3	4	5
		1	2	3	4	5
Nível de Consequências (N)						

Quadro 5 - Matriz de significância

- P x N maior ou igual a 16 -> Significativo
- P x N igual a 8 ou 15 -> Moderado
- P x N menor que 8 -> Aceitável

8. AVALIAÇÃO DOS CONTROLES EXISTENTES

Nesta etapa, deve-se identificar e avaliar os controles que a empresa já aplica em relação a cada risco identificado. Controles existentes podem incluir:

- Procedimentos documentados para execução das atividades, incluindo a definição clara de critérios, responsabilidades e autoridades;
- Automatização de processos, com mecanismos para prevenir erro humano;
- Procedimentos de comunicação interna e externa;
- Treinamento de funcionários;
- Uso de redundâncias;
- Uso de fornecedores qualificados;
- Controles previstos no Anexo A da NBR ISO/IEC 27001 etc.

A avaliação deve ser feita levando em consideração para cada risco que está sendo avaliado, já que um conjunto de controles pode ser eficaz para alguns riscos, mas não para outros.

Para avaliação da eficácia, considera-se o quanto os controles existentes, em conjunto, conseguem atenuar os riscos, utilizando-se a escala apresentada no quadro 4:

Nota	Descrição	Significado
1	Inexistente ou inicial	Inexistente (Controles inexistentes, mal desenhados ou mal implementados, isto é, não funcionais) ou em fase inicial (há evidência de que a organização reconhece que o processo existe e que as necessidades devem ser resolvidas. Entretanto não há um processo padronizado e o gerenciamento é caso a caso e desorganizado). Portanto, o efeito sobre os riscos é nulo ou muito pequeno.
2	Repetível	Os processos são estruturados e procedimentos similares são seguidos por diferentes indivíduos para a mesma tarefa. Há forte dependência do conhecimento individual e existe alguma documentação). Portanto, não conseguem reduzir as probabilidades nem reduzir as consequências a um nível aceitável na maioria das vezes.
3	Definido	Os processos são padronizados, documentados e comunicados. Entretanto, fica a cargo dos indivíduos seguirem os processos. Não há certeza de que os desvios serão detectados. Sendo assim, conseguem reduzir as probabilidades e/ou reduzir as consequências a um nível aceitável algumas vezes, mas apresentam falhas.
4	Gerenciado	Existe a possibilidade de monitorar e medir a conformidade dos processos com os procedimentos definidos. Há ações para melhoria implementadas. Conseguem reduzir as probabilidades e/ou reduzir as consequências dos riscos a um nível aceitável na maioria das vezes, com poucas falhas.
5	Otimizado	Os processos associados foram refinados e podem ser considerados a “melhor prática”, mitigando todos os aspectos relevantes do risco.

Quadro 6 - Escala para avaliação da eficácia dos controles existentes

9. AVALIAÇÃO DA NECESSIDADE DE TOMADA DE AÇÃO ADICIONAL AOS CONTROLES EXISTENTES

Com base na análise dos fatores mencionados no item 6 deste procedimento, deve ser feita a avaliação da necessidade de ações adicionais aos controles já existentes, com base na matriz apresentada no quadro 5.

A tomada de decisão com relação à aceitação dos requisitos de mudança deve levar em consideração os riscos, impactos potenciais no serviço e no cliente, requisitos do serviço, benefícios para o negócio, viabilidade técnica e impacto financeiro.

P x G	Significativo	IV	III	II	II	I
	Moderado	IV	III	III	II	II
	Aceitável	IV	IV	IV	IV	IV
		5	4	3	2	1
		Eficácia dos controles				

Quadro 5 - Matriz de decisão

- Devem ser tomadas medidas de controle no prazo mais rápido possível.
- Devem ser tomadas medidas de controle com base em plano de ação de curto ou médio prazo.
- A implementação dos controles adicionais ou revisão nos controles existentes devem considerar o custo-benefício. Se a redução na significância for muito menor que o custo para implementação, os controles não serão implementados.
- Nenhuma medida adicional de controle é necessária.

A tomada de decisão com relação à aceitação dos requisitos de mudança deve levar em consideração os riscos, impactos potenciais no serviço e no cliente, requisitos do serviço, benefícios para o negócio, viabilidade técnica e impacto financeiro.

10. PLANO DE AÇÃO

Se ações adicionais aos controles já existentes forem consideradas necessárias, deverão ser elaborados planos de ação para tratar com os riscos residuais, eliminando as causas ou reduzindo as consequências. As ações mais comuns envolvem as seguintes estratégias genéricas:

a) Evitar:

O risco pode ser evitado através da eliminação do perigo/ameaça ou ao realizar o processo de uma forma diferente. Sempre que possível, essa deve ser a estratégia a ser adotada.

b) Transferir ou compartilhar:

Transferência ou compartilhamento de risco envolve encontrar uma outra parte que possa arcar - total ou parcialmente - com a responsabilidade do risco, caso ocorra. Essa estratégia não elimina o risco, mas compartilha as responsabilidades. O objetivo é garantir que o risco é gerenciado pela parte capaz de lidar com ele da forma mais eficaz. Por exemplo, uso de seguros, definição clara de responsabilidades que os clientes devem assumir etc.

c) Reduzir:

A redução de riscos ocorre pela diminuição da probabilidade e/ou a consequência para um limite aceitável pela empresa.

Ao planejar as ações, deve-se ter em mente que há algumas condições a serem consideradas, que podem prejudicar ou limitar o alcance dos resultados:

- Restrições temporais – O controle pode ser implementado durante o período de vida útil da informação ou do sistema? Que período é aceitável para ficar exposto a um determinado risco (enquanto a ação é implementada)?
- Restrições financeiras – a implementação ou a manutenção dos controles não devem ser mais custosos do que o valor dos riscos que eles foram projetados para proteger
- Restrições técnicas e operacionais – Por exemplo, envolvendo a integração de controles novos a uma infraestrutura existente e a interdependência entre controles
- Restrições éticas e legais etc.

11. DOCUMENTAÇÃO

A documentação do processo de identificação, análise e avaliação dos riscos deve ser feita através de planilhas por processo, conforme modelos apresentados nos Anexos 01 e 02.

a) Matriz de Risco para uso no SGS

Onde aplicável, as matrizes identificarão riscos relacionados com o envolvimento de outras partes no ciclo de vida do serviço. Para facilitar a identificação da conformidade à NBR ISO-20000-1, as matrizes serão agrupadas por áreas, dentro de cada processo (onde aplicável):

- Riscos para Continuidade e a Disponibilidade de serviço (**CD**)
- Riscos para a Gestão da Configuração (**CF**)
- Riscos gerais (**G**)
- Outras Partes (**OP**)

b) Matriz de Risco para uso no SGSI

As matrizes de riscos relacionadas à segurança da informação serão organizadas por grupos de ativos, conforme inventário realizado.

12. AVALIAÇÃO DA EFICÁCIA DO TRATAMENTO

A eficácia do tratamento de riscos deve julgar o quanto as ações e medidas implementadas conseguiram reduzir ou controlar os riscos identificados.

Para tanto, é necessário que haja um tempo suficiente para que os efeitos desejados pelas ações produzam os efeitos sobre os processos e ativos de informação envolvidos.

A avaliação da eficácia do tratamento de riscos pode ser realizada por uma ou mais das seguintes formas:

- Revisão nas matrizes de riscos, alterando a pontuação sobre a eficácia dos controles (ver quadro 4)
- Acompanhamento de indicadores associados aos riscos que foram tratados. Por exemplo: SLA, N° de incidentes de segurança etc.
- Constatações realizadas pelas auditorias
- Análise crítica pela direção

É possível que o tratamento do risco não resulte em um nível de risco residual que seja aceitável. Nessa situação, será necessária uma outra iteração do processo de avaliação de riscos, seguida por uma fase adicional de tratamento do risco.

13. ANEXOS

Anexo 01 – Modelo de Matriz de Risco para uso no SGS

Anexo 02 – Modelo de Matriz de Risco para uso no SGSI

13

14